ISO 27001:2022'nin ana maddeleri (Clauses) aşağıdaki şekildedir:

Clause	Başlık
4	Context of the Organization
5	Leadership
6	Planning
7	Support
8	Operation
9	Performance Evaluation
10	Improvement

Clause 4 – Context of the Organization

4.1 Understanding the Organization and its Context

Kuruluşun iç ve dış bağlamının belirlenmesi

4.2 Understanding the Needs and Expectations of Interested Parties

İlgili tarafların gereksinimlerinin belirlenmesi

4.3 Determining the Scope of the ISMS

BGYS kapsamının belirlenmesi

4.4 Information Security Management System

BGYS'nin kurulması, uygulanması ve sürdürülmesi

Clause 5 – Leadership

5.1 Leadership and Commitment

5.2 Information Security Policy

5.3 Organizational Roles, Responsibilities and Authorities

Clause 6 – Planning

6.1 Actions to Address Risks and Opportunities

6.1.1 General

6.1.2 Information Security Risk Assessment

6.1.3 Information Security Risk Treatment

6.2 Information Security Objectives and Planning

6.3 Planning of Changes

Clause 7 – Support

7.1 Resources

7.2 Competence

7.3 Awareness

7.4 Communication

7.5 Documented Information

7.5.1 General

7.5.2 Creating and Updating

7.5.3 Control of Documented Information

Clause 8 – Operation
8.1 Operational Planning and Control
8.2 Information Security Risk Assessment
8.3 Information Security Risk Treatment

Clause 9 – Performance Evaluation
9.1 Monitoring, Measurement, Analysis and Evaluation
9.2 Internal Audit
9.3 Management Review

Clause 10 – Improvement
10.1 Continual Improvement
10.2 Nonconformity and Corrective Action

ISO 27001 Denetimlerinde En Çok Bulgu Çıkan Clauses

Bir ISMS audit labı hazırlıyorsan öğrencilerin en çok bulgu çıkaracağı alanlar:

Clause	Tipik Bulgular
4.3	Scope eksik
5.2	Politika güncel değil
5.3	Roller ve sorumluluklar tanımlı değil
6.1.2	Risk metodolojisi eksik
6.1.3	Risk treatment plan eksik
6.2	KPI içermeyen hedefler
7.2	Eğitim kayıtları eksik
7.3	Awareness eksik
7.5	Doküman kontrol eksikliği
8.1	Operasyonel kontroller uygulanmıyor
9.1	Güvenlik metrikleri yok
9.2	İç denetim yapılmamış
9.3	Management Review eksik
10.2	Corrective action takibi yapılmıyor

ISO 27001:2022 Annex A Kontrolleri

2022 versiyonunda toplam **93 kontrol** vardır:

Domain	Kontrol Sayısı
A.5 Organizational Controls	37
A.6 People Controls	8

A.7 Physical Controls	14
A.8 Technological Controls	34